PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Mécanismes de sécurité Windows Server 2008

09-110 PSE-ER F1-11 Windows Server 2008 - mécanismes de sécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le noyau NT 6.0 utilise PatchGuard et KMCS pour protéger le système contre les rootkits et le code non signé.
2. Le processus LSASS gère l'identification et les stratégies de sécurité via les bases SECURITY et SAM dans le Registre.
3. Le contrôle d'accès et l'audit s'effectuent uniquement à l'ouverture de l'objet et non pendant son utilisation.

Objectifs et mécanismes de sécurité

Notion	À retenir
Le but de la sécurité	Empêcher les **accès non autorisés** aux données sensibles et protéger **fichiers**, **mémoire** et **configuration** contre les intrusions.
Les exigences fondamentales	Mécanismes natifs : couple **login/mot de passe**, **listes de contrôle d'accès**, **droits/privilèges** et contrôle des **actions des programmes**.
Les caractéristiques de niveau supérieur	Windows est un **système distribué**, pour **système embarqué**, avec **protection données sensibles**, **pare-feu**, **administration bureau/réseau**, **annuaire**, **VPN**, **PKI** et **certificats**.
La protection du noyau	**Noyau NT 6.0** ; **PatchGuard** bloque rootkits et modifications du noyau ; contrôle d'intégrité des exécutables, dont **KMCS** (code noyau signé par une autorité approuvée).

Composants du système de sécurité

Notion	À retenir
Composants noyau	Le **SRM** (exécutif `Ntoskrnl.exe`) définit les jetons d'accès, contrôle les objets, manipule les droits et gère l'audit. **KSecDD** est une bibliothèque noyau utilisée par **EFS** pour communiquer avec **LSASS**.
Processus LSASS	L'image `Lsass.exe` gère l'identification, les stratégies de mot de passe et les droits. Bases : **SECURITY** (`HKLM`) pour les stratégies, **SAM** (`HKLM`) pour les utilisateurs locaux via `Samsrv.dll`, et **Active Directory** via `Ntdsa.dll`.
Ouverture de session	**Winlogon.exe** gère les sessions et crée le shell. **LogonUI** (fils de Winlogon) utilise des **credential providers** (`authui.dll`, `SmartcardCredentialProvider.dll`) pour l'authentification. **Netlogon** crée le canal sécurisé vers le contrôleur de domaine.

Services et composants de sécurité

Notion	À retenir
Les fonctionnalités offertes	Les **systèmes Windows** offrent : discrimination (**besoin d'en connaître**), protection de l'**intégrité** des ressources partagées, **authentification** et prévention d'accès aux ressources non initialisées.
Objets, descripteurs et jetons	Objets (**File**, **Process**, **Key**) protégés par un **descripteur de sécurité**. L'accès est assuré par un processus via un **jeton d'accès** (contexte de sécurité).

Acteurs et concepts du modèle

Notion	À retenir
Le compte utilisateur	Authentifie et autorise l'accès à un ordinateur, un réseau et l'annuaire. Composé d'un **nom d'utilisateur** et d'un élément de restriction (ex: **mot de passe**).
Le Security Identifier	Le **SID** identifie de façon unique un compte au sein d'une autorité. Format : `S-R-I-suite` (ex: `S-1-5-21-...-500` pour l'**Administrateur** local).
Le login et le mot de passe	Le **login** (max **256** caractères, non sensible à la casse) et le **mot de passe** sécurisent le compte. SAM : max **14** caractères ; Active Directory : max **127**.
Les groupes et stratégies	Les utilisateurs héritent des droits du groupe. Groupes : **Sécurité** ou **Distribution**. Les **stratégies de groupe** appliquent des paramètres automatiquement aux objets (conteneur, site, domaine, OU).
Le domaine	Espace de confiance : un **contrôleur de domaine** centralise comptes et authentifications ; compte de domaine utilisable sur tout ordinateur du domaine, compte local limité à sa machine.

Synthèse du modèle de sécurité

Notion	À retenir
Modèle de sécurité Windows	Supporte **3 services fondamentaux** : l'**authentification**, le **contrôle d'accès** et l'**audit**.
L'authentification	Vérifie l'identité pour l'ouverture de session ou l'accès aux ressources. Supporte l'**ouverture de session unique** (SSO).
Protocoles d'authentification	**Kerberos V5** (principal, authentification mutuelle), **SSL/TLS** (web), **NTLM** (NT 4.0 ou antérieur : **mode mixte**, défaut), **Digest** (hachage **MD5**), **Passport**.

Synthèse du contrôle d'accès

Notion	À retenir
Principe et contrôle	Accès via une **référence** obtenue à l'**ouverture** ; contrôle et audit à l'ouverture seulement. Rapproche permissions demandées, **descripteur** de l'objet et **jeton** du processus.
Droits et autorisations	Les **droits** s'appliquent à un **compte** (individu/groupe). Les **autorisations** s'appliquent aux **objets** (fichiers, AD, Registre, processus).
Audit des objets	L'administrateur définit une **politique d'audit** (type d'événements). Les événements sont consignés dans le **journal de sécurité**.

Structures de données de sécurité

Notion	À retenir
Le descripteur de sécurité	Contient le **SID du propriétaire**, la **DACL** et la **SACL**. Le propriétaire peut toujours **lire et modifier** sa **DACL**. ACE **positive** = accorde, **négative** = refuse.
Le jeton	Attaché au processus : identité et attributs d'autorisation (**SID** du propriétaire, des groupes, du type et de la session de connexion), sécurité par défaut des nouveaux objets.

Pièges et confusions

- ⚠ Confondre le moment du contrôle d'accès (uniquement à l'ouverture) avec son utilisation continue.
- ⚠ Oublier que les permissions restent valables tant que l'objet est ouvert, même si les droits changent.
- ⚠ Confondre la limite de caractères du mot de passe SAM (14) avec celle d'Active Directory (127).
- ⚠ Croire qu'une ACE négative accorde un accès : elle le refuse (masque de permissions).
- ⚠ Confondre le rôle de PatchGuard (protection noyau) avec celui du KMCS (signature du code).

Sigles et définitions

SID	Identifiant de sécurité unique pour un compte au sein d'une autorité.
DACL	Liste d'entrées de contrôle d'accès indiquant les accès possibles pour quels SID.
SACL	Liste de contrôle d'accès système contenant les informations d'audit.
ACE	Entrée d'une DACL listant les accès accordés ou refusés à un SID.
Jeton d'accès	Structure attachée à un processus définissant son contexte de sécurité.
RID	Identifiant relatif terminant un SID.

Auto-test

1. Quel est le numéro RID du principal Administrateur d'un système local ?
2. Quelle technologie protège le noyau contre les rootkits ?
3. Quelle est la limite de caractères pour un login ?
4. Quel protocole est le paramètre par défaut en mode mixte ?
5. Qui peut toujours lire et modifier la DACL d'un objet ?

Réponses : **1.** 500 · **2.** PatchGuard · **3.** 256 · **4.** NTLM · **5.** Le propriétaire

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.